

课程讲义

AI 红队课程开篇

洺熙-AI 安全 & Codex

2026 年 5 月 16 日



视频作者 / 频道：洺熙-AI 安全

发布日期：2026-05-13

视频时长：10:49

视频链接：<https://www.bilibili.com/video/BV11c516gEvJ>

素材说明：平台无可下载字幕，本讲义基于 Whisper 转写、视频画面与课程封面整理。

目录

1	课程定位：AI Red Teaming 要解决什么	3
1.1	本章要解决什么问题	3
1.2	课程开场与核心承诺	4
1.3	首次定义：AI Red Teaming	4
1.4	首次定义：AI 安全与攻击面	4
1.5	本章小结	5
2	讲师背景与课程可信度	5
2.1	讲师身份与网络安全背景	6
2.2	证书、CVE 与实践经验	6
2.3	教学背景与课程表达能力	7
2.4	写作边界：只保留与课程有关的履历	7
2.5	本章小结	7
3	攻击主题全景：从 Prompt 到 ML 生命周期	7
3.1	Prompt Injection 与 Jailbreaking	9
3.2	Adversarial ML: FGSM、PGD、C&W	9
3.3	RAG 与 Vector DB 攻击面	10
3.4	Data Poisoning、Backdoors 与 Trigger	10
3.5	C2/C2C Kill Chains 与 Full Red Teaming	11
3.6	本章小结	11
4	开始前要求：学习者需要什么基础	12
4.1	本章要解决什么问题	12
4.2	Python 基础	12
4.3	命令行舒适度	13
4.4	AI/ML 基础意识	13
4.5	好奇心与黑客思维	14
4.6	硬件与运行环境	14
4.7	Google Colab	14
4.8	本章小结	15
5	课程路线图：模块、实验与交付物	15
5.1	路线图的读法：从 M0 到 M11	15
5.2	M1-M2: 基础与工具	16
5.3	M3-M6: 提示词、越狱、RAG 与对抗 ML	17
5.4	M7-M10: 投毒、模型窃取、供应链与完整红队流程	17

5.5	M11: 防御与未来威胁	18
5.6	交付物数字: 28 labs、28 answer notes 与 C2C kill chains	18
5.7	本章小结	18
6	学习方法与视觉规则: 理论、Demo、Lab、Challenge	18
6.1	四段式学习循环	19
6.2	理论与图示: 先建立问题框架	20
6.3	Demo 与 Hands-on Lab: 从观看到执行	20
6.4	Challenge 与 Answer Notes: 自测与复盘	20
6.5	幻灯片颜色约定	21
6.6	本章小结	21
7	合规边界、工具箱与最终总结	22
7.1	本章要解决什么问题	22
7.2	Rules of Engagement: 授权优先	22
7.3	实验室环境与 Responsible Disclosure	22
7.4	防御目标: break to protect	23
7.5	Your Arsenal: 课程工具箱	25
7.6	最终总结: 从开篇到 Foundations	25
7.7	本章小结	26

1 课程定位：AI Red Teaming 要解决什么

1.1 本章要解决什么问题

本章先给整门课定边界：这门课讨论的是一套面向真实 AI 系统的安全评估方法。它的核心问题是：当 AI 系统已经进入真实产品、真实流程和真实决策链路时，安全团队如何系统地发现风险、验证风险，并把验证结果转化为防御改进。

开场字幕把课程描述为一份面向 AI 系统的完整指南，画面标题对应 *AI Red Teaming*，副标题强调 *Breaking, Testing & Securing AI Systems*。因此，本课程的第一层承诺可以拆成三个动词：发现系统会怎样被攻破，测试这些风险是否真实存在，再把测试结果用于保护 AI 系统。画面还给出几个精确标签：*Practical Masterclass - 2026 Edition*、*Offensive AI*、*C2C Methodology*、*160+ Slides* 与 *8 Professional Tools*。字幕里与年份和页数相关的识别需要按画面校正：这里应理解为 2026 edition 与 160+ slides。

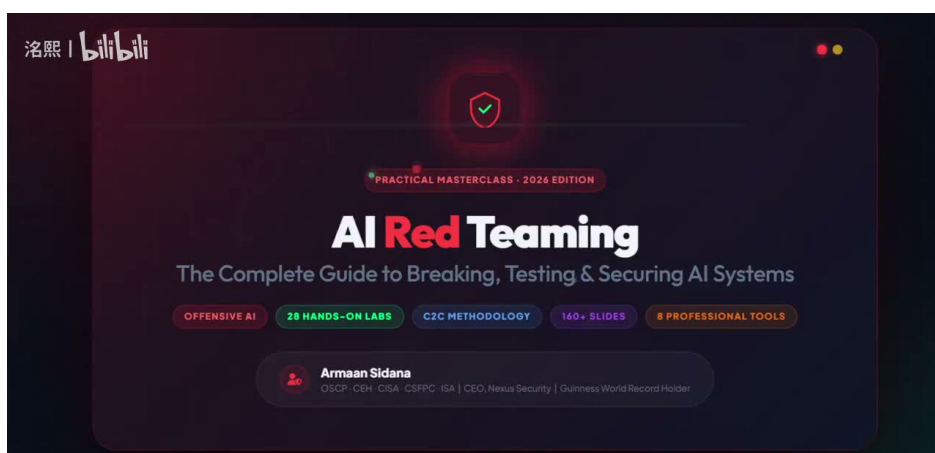


图 1: 课程开场标题页显示 AI Red Teaming 以及 Breaking, Testing & Securing AI Systems 副标题，用于在本章建立课程定位和 AI 安全主题边界。（视频画面时间区间：00:00–00:15；抽帧点约 00:00:04。）

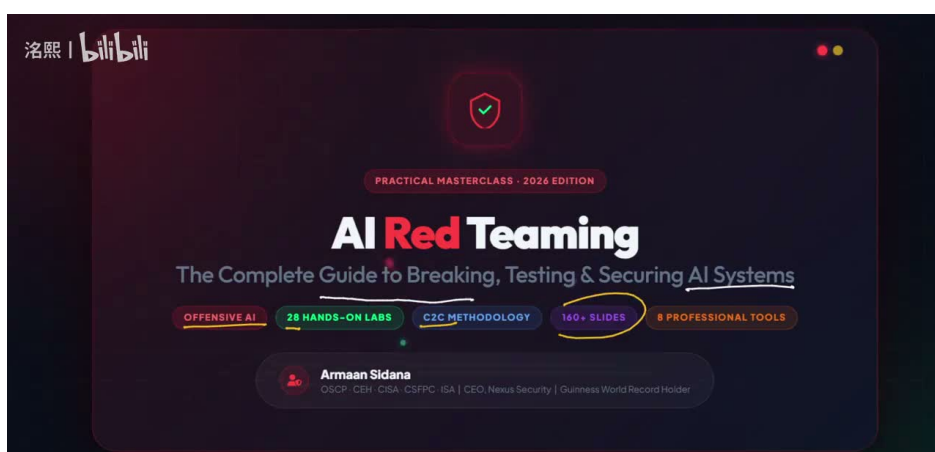


图 2: 开场页中的课程规模标签标出 hands-on labs、C2/C2C 相关内容、slides 和 professional tools 等要素，用于提示本课程覆盖面和学习产出，不展开为具体操作细节。（视频画面时间区间：00:20–00:50；抽帧点约 00:00:26。）

课程第一层承诺

AI Red Teaming 的课程定位可以概括为一句话：用授权、可控、可复核的红队评估，帮助组织看见 AI 系统在模型行为、数据链路、提示词上下文、工具调用和部署接口上的真实风险。

1.2 课程开场与核心承诺

00:00–00:55 的开场没有进入具体攻击技术，它主要完成三件事。第一，讲师宣布这是新的 AI Red Teaming 课程。第二，课程会覆盖 AI 攻击、测试与保护，也就是从风险发现走到安全加固。第三，画面和字幕预告课程规模：大约 28 个 hands-on labs、C2C 相关内容、160+ slides，以及 8 个 professional tools。

这些数字在本章只承担“课程规模”的作用。28 个 labs 表示学习者会有实验入口；160+ slides 表示课程材料较完整；8 个 professional tools 表示课程会接触实际安全工作流。这里的 Offensive AI 说明课程站在进攻性安全评估视角组织内容；后文所有练习仍受授权和实验室边界约束。C2C 在这里仅作预告，后文会在相应章节再解释其课程语境，当前章节不抢占定义。

字幕中还出现了“资料较新”的表达。由于 SRT 存在明显 ASR 误听，本章只保留这个教学含义：课程试图回应当前 AI 安全实践中的新问题，尤其是传统网络攻防经验迁移到 AI 系统时遇到的变化。

1.3 首次定义：AI Red Teaming

术语类比：AI 红队与传统渗透测试

AI Red Teaming，中文可写作“AI 红队测试”，指围绕 AI 系统开展的授权式攻防评估与防御改进流程。它关注攻击者可能影响系统的路径，也关注安全团队如何把发现转化为修复、监控和治理。

传统渗透测试常把网站、主机、网络、权限边界看作主要对象。AI Red Teaming 仍然继承“授权测试、证据记录、风险评级、修复建议”这套工程纪律，但评估对象发生了扩展：模型会生成内容，提示词会改变行为，训练数据会留下偏差，检索系统会引入外部知识，工具调用会把模型输出接到真实动作上。

更麻烦的是，AI 系统具有非确定性。对于同一个输入，模型可能在不同上下文、不同温度参数、不同检索结果下给出不同输出。安全评估因此不能只看“某个接口是否返回 200”，还要看模型行为是否稳定、边界是否清晰、失败模式是否可解释。

常见误解

本课程中的“攻破”只服务于授权测试与防御改进。讲义不会给出可滥用的攻击步骤、payload 或绕过模板；所有攻击主题都应被理解为风险建模与安全验证的教学对象。

1.4 首次定义：AI 安全与攻击面

AI 安全指保护 AI 系统在设计、训练、部署和使用过程中的可靠性、机密性、完整性、可用性与合规性。它覆盖的不只是模型本体，还包括数据、提示词、检索链路、工具链、API、部署环境和用户交互。可以把 AI 系统想成一条“认知供应链”：数据进入系统，模型加工信息，检索模块补充上下文，工具把结果接到外部世界，用户再把反馈带回系统。

攻击面，英文为 *Attack Surface*，是指可能被攻击者影响、调用、污染、绕过或观测的入口集合。用集合视角看攻击面，有助于学习者把零散风险放进同一张地图里。这里先给出一个轻量表示：

$$\mathcal{A}_{AI} = \{prompt, data, model, retrieval, tool, API, deployment, user\}$$

这个公式不做复杂推导，只用于帮助读者建立结构感。各符号含义如下：

- $\mathcal{A}_{AI}$ ：AI 系统的攻击面集合，也就是安全评估需要关注的入口总表。
- *prompt*：提示词与上下文输入，影响模型如何理解任务。
- *data*：训练数据、评估数据、检索文档和用户上传内容。
- *model*：模型参数、推理行为、输出边界和对齐策略。
- *retrieval*：RAG 或搜索链路中的检索、排序、拼接与引用过程。
- *tool*：模型可调用的外部工具，例如插件、函数、脚本或业务动作。
- *API*：供模型或应用访问的接口、鉴权和速率限制。
- *deployment*：运行环境、模型服务、日志、配置和供应链依赖。
- *user*：操作者、审核者、终端用户以及他们与系统之间的交互习惯。

这组元素解释了为什么 AI 安全会比“模型准不准”更宽。模型准确率只像体检中的一个指标，攻击面则像整栋楼的门、窗、通风管、电梯、门禁和监控。安全团队要关心的不止是模型回答得好不好，还要关心谁能影响它、它能调用什么、它会泄露什么、它出错后会把影响传到哪里。

攻击面集合

AI 安全的关键观察是：风险常常出现在连接处。提示词连接用户与模型，检索连接外部知识与上下文，工具连接模型输出与真实动作，API 连接 AI 应用与业务系统。连接越多，攻击面越大，治理也越需要体系化。

1.5 本章小结

本章完成了三项基础定义。AI Red Teaming 是围绕 AI 系统的授权式攻防评估与防御改进流程；AI 安全覆盖模型、数据、提示词、工具链、部署接口和人机交互；攻击面是所有可能被影响、调用、污染、绕过或观测的入口集合。开场提到的 28 个 labs、C2C、160+ pages 和专业工具，说明课程会从概念进入实验与工具，但本章的重点仍是定位：用红队视角提升 AI 系统的安全性。

2 讲师背景与课程可信度

本章使用的字幕时间范围为 00:55–02:11。上一章已经给出 AI Red Teaming 的课程定位：围绕 AI 系统做授权式攻防评估、风险发现和防御改进。本章暂时不展开攻击技术本身，只回答一个更基础的问题：讲师凭什么来讲这门从网络攻防迁移到 AI 安全的课程。

2.1 讲师身份与网络安全背景

画面与字幕在这一段引出讲师 Armaan Sidana。字幕把姓名识别成“阿尔曼-Sidana”等形式，按画面与契约统一写作 Armaan Sidana。课程在这里展示的是讲师的安全背景页：证书、漏洞编号、网络安全 portfolio，以及与安全教育相关的经历。

这类介绍在安全课程中有实际意义。安全判断不能只靠概念堆叠，真正的判断往往来自长期接触系统边界、漏洞报告、复现环境、风险沟通和教学反馈。讲师在开场展示这些材料，目的在于让学习者知道：后续讨论 AI Red Teaming 时，课程视角来自传统网络安全经验向 AI 安全问题的迁移。

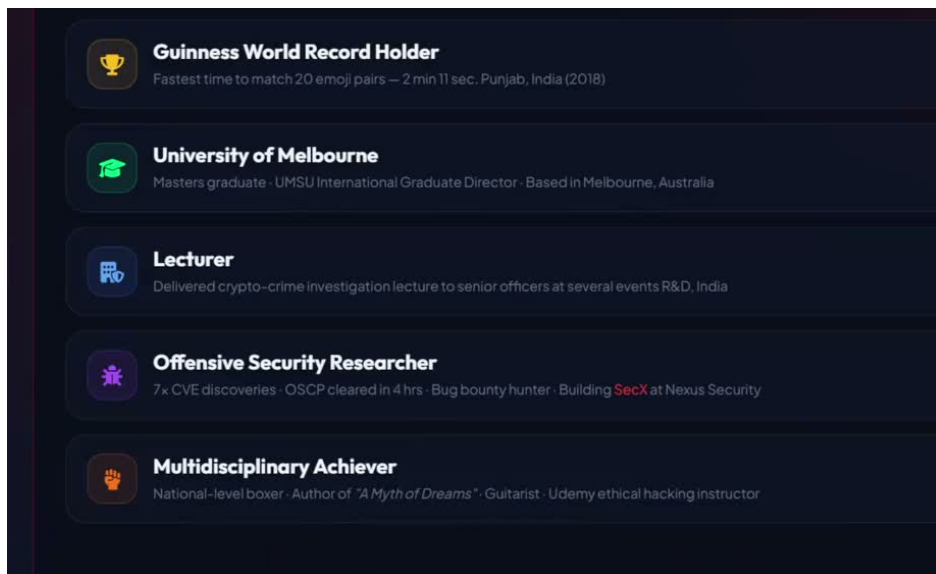


图 3: 讲师背景页的局部裁剪展示 Guinness World Record Holder、University of Melbourne、Lecturer、Offensive Security Researcher 等经历条目，用于说明课程可信度来自安全实践、教学和跨领域经验。（视频画面时间区间：00:55–02:05；抽帧点约 00:01:05。）

2.2 证书、CVE 与实践经验

字幕提到讲师持有 OSCP 等多项安全证书，并提到约 7 个 CVE。由于字幕对若干证书缩写存在明显识别噪声，本讲义只确认契约中要求的核心事实：讲师具备网络安全认证背景，并有公开漏洞编号相关经历。那些听不清、画面不够稳定的称号和头衔，不在正文里强行坐实。

术语速记：OSCP 与 CVE

OSCP 通常指 Offensive Security Certified Professional，是偏实践型的渗透测试认证，强调在受控环境中发现、验证和报告漏洞。CVE 是 Common Vulnerabilities and Exposures 的缩写，可理解为公开漏洞的“身份证号”：同一个漏洞有了统一编号，研究者、厂商、防守团队和课程材料才能围绕同一对象沟通。粗略地说，若把漏洞知识库看成集合 V ，一个 CVE 编号就是集合中某个漏洞条目的稳定索引 $v_i \in V$ 。

对学习者来说，证书和 CVE 不能自动保证课程质量，但它们能说明讲师接触过真实的攻防流程。证书说明其接受过系统化的实践训练；CVE 说明其参与过可公开追踪的漏洞识别或披露链路。两者合在一起，支撑了本课程“从安全工程经验切入 AI 红队测试”的可信度。

2.3 教学背景与课程表达能力

字幕中还提到讲师曾在不同学校或教育场景中授课，不过这一句的 ASR 失真很严重，出现了长串重复词。因此，本讲义只保留与课程可信度有关的结论：讲师具备一定教学和公开讲解背景。安全课程尤其依赖表达能力，因为学习者需要理解的不只是“漏洞存在”，还包括漏洞为什么出现、攻击面如何形成、风险怎样被复现与修复。

可以把这门课的可信度拆成三个维度：

$$Credibility = Practice + Disclosure + Teaching$$

其中 *Practice* 指网络安全实战经验，*Disclosure* 指 CVE 这类可追踪的漏洞披露经历，*Teaching* 指把复杂攻防问题转译成课程路径的能力。这个公式只承担解释功能，帮助读者把“讲师背景”看成三类证据，避免单纯按头衔数量判断可信度。

2.4 写作边界：只保留与课程有关的履历

这一段字幕还出现了一些个人履历和兴趣信息，例如世界纪录、学习经历、拳击、写书、音乐等。它们可以让人物更立体，但对本课程的技术可信度帮助有限。因此，本章不展开这些内容，也不把字幕中含混的个人称号写成确定事实。

本章真正需要留下的判断是：Armaan Sidana 在开场建立了传统网络安全、漏洞披露、认证训练和教学表达四个支点。后续课程讨论 Prompt Injection、Adversarial ML、RAG 攻击面和 Full Red Teaming 时，读者应把这些主题理解为网络安全方法论进入 AI 系统后的延伸，避免把它们看成孤立的热门术语清单。

2.5 本章小结

本章完成了课程可信度的交代：讲师 Armaan Sidana 以网络安全经验为基础，展示了 OSCP 等证书背景、约 7 个 CVE 的漏洞披露经历，以及教学相关背景。CVE 提供公开漏洞沟通的统一编号，OSCP 代表偏实践的攻防训练。个人履历中与课程无关或字幕不清楚的部分，本讲义不强行确认。接下来课程将转入攻击主题全景，开始说明 AI Red Teaming 会覆盖哪些具体攻击面与风险类别。

3 攻击主题全景：从 Prompt 到 ML 生命周期

本 section 使用的字幕时间范围为 02:11–04:10。本章要解决的问题很直接：这门课到底会把哪些 AI 攻击主题放进同一张地图里？前文已经把 AI Red Teaming 定义为围绕 AI 系统的授权式攻防评估与防御改进流程，本章沿用这个定义，把攻击面拆成提示词层、检索层、数据层、模型层和项目交付层来看。

安全边界

本章只做攻击主题的概念级总览。所有术语都服务于理解风险、组织课程路线和建立防御意识；这里不会给出可直接复用的攻击 payload、绕过话术或未授权测试步骤。

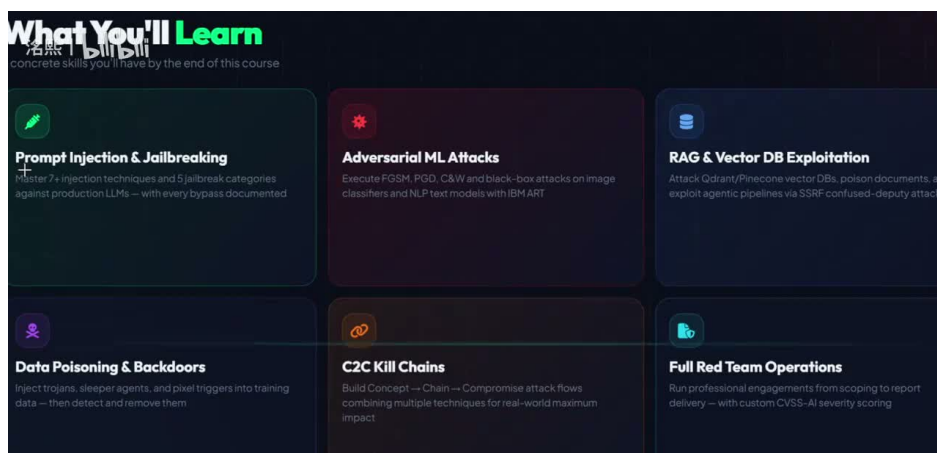


图 4: What You'll Learn 六宫格总览展示 Prompt Injection、Adversarial ML、RAG & Vector DB、Data Poisoning、C2/C2C mechanisms 和 Full Red Team Operations，用于把本章攻击主题组织成一张概念地图。（视频画面时间区间：02:15–03:45；抽帧点约 00:02:16。）

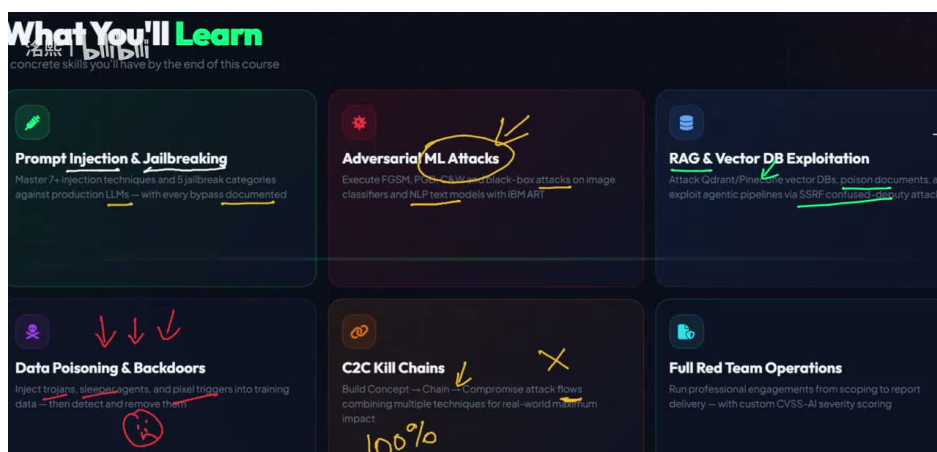


图 5: 讲师在同一主题总览页上标出 Adversarial ML、RAG & Vector DB、C2/C2C mechanisms、CVSS-AI 和 Full Red Team Operations 等重点，用于说明本章会从单点主题延伸到评估与交付视角。（视频画面时间区间：03:45–04:05；抽帧点约 00:03:46。）

3.1 Prompt Injection 与 Jailbreaking

Prompt Injection（提示词注入）指攻击者通过用户输入、外部文档、网页内容、工具返回值或上下文片段，影响大语言模型的指令理解与执行意图。可以把 LLM 想成一位正在读多张便签的助理：系统提示词像主管贴在桌上的规则，用户提示词像当前任务说明，检索到的文档像临时资料。Prompt Injection 的核心风险在于，有人把伪装成资料的“新便签”混进来，让助理把资料当命令，把噪声当优先级。

Jailbreaking（越狱）指试图绕过模型安全对齐、内容策略或行为边界的一类技术。它关注的是模型“愿意回答什么、拒绝什么、如何拒绝”。如果 Prompt Injection 更像污染上下文中的指令层级，Jailbreaking 更像压测模型的安全护栏：同一个模型在不同表述、不同角色设定、不同上下文压力下，可能表现出不同的拒答稳定性。

两者都发生在 LLM 行为控制层，但观察角度不同：Prompt Injection 常见于应用集成场景，尤其是 RAG、插件、Agent、工具调用链；Jailbreaking 常见于模型安全评估场景，用来检查 RLHF 绕过风险。这里的 **RLHF（Reinforcement Learning from Human Feedback）**是指用人类反馈强化模型偏好的对齐方法，**RLHF 绕过**则是规避这类安全偏好的风险类别。

画面把这一学习目标放在 production LLMs 的评估语境中，并强调 every bypass documented。这里的 documentation 指安全评估中的证据记录：测试对象、模型版本、输入上下文、观察到的响应、拒答或失效模式、风险判断和修复线索。它不等同于收集绕过话术；课程真正强调的是让每次观察都能被复核、被报告、被用于防御改进。

不要把概念总览当作操作说明

提示词攻击最容易被误解成“写几句神奇口令”。真实系统里的风险通常来自上下文边界不清、外部内容可信度不足、工具权限过大、日志与审计缺失。学习时应关注输入通道、权限边界和失败模式，避免把课程内容变成话术收集。

3.2 Adversarial ML: FGSM、PGD、C&W

Adversarial ML（对抗机器学习）研究如何让机器学习模型在细微扰动、分布变化或边界样本面前产生错误判断。它的典型场景包括图像分类器、NLP 模型和文本模型。直观类比是：人眼看一张图片仍然觉得是同一件物体，模型却因为某些微小变化把它分到另一个类别；读者看一句话没有明显歧义，分类器却在边界附近改变判断。

安全的抽象表示可以写成：

$$f_{\theta}(x) = y, \quad f_{\theta}(x + \delta) = y', \quad y' \neq y, \quad \|\delta\| \leq \epsilon.$$

其中 f_{θ} 表示参数为 θ 的模型， x 是原始输入， δ 是受约束的扰动， ϵ 表示扰动幅度上限。这个公式的作用是帮助读者看清对抗样本的本质：攻击者试图在“变化很小”的输入空间里，让模型输出跨过决策边界；它不提供构造扰动的操作方法。

FGSM（Fast Gradient Sign Method，快速梯度符号法）是一类基于梯度方向理解模型脆弱性的经典方法。它像顺着山坡最陡方向推一小步：如果模型的损失函数告诉评估者“往哪个方向更容易出错”，FGSM 就用这个方向解释单步扰动为什么能暴露鲁棒性问题。

PGD（Projected Gradient Descent，投影梯度下降）可以理解为多步迭代式压力测试。它每次只走一小步，并把扰动限制投影回允许范围内；类比在一个小圆圈里反复试探边界，寻找最容易让模型失误的位置。字幕此处按标准术语整理为 PGD。

C&W（Carlini-Wagner Attack）是一族经典对抗样本攻击方法，常用于研究模型决策边

界、置信度和鲁棒性评估。字幕此处按标准术语整理为 C&W。课程在这里点名 FGSM、PGD、C&W，主要是告诉学习者：AI 红队除了提示词层，还会进入模型行为与机器学习鲁棒性层。

画面还把 **black-box attacks** 与 IBM ART 放在同一学习目标中。Black-box 在这里指评估者主要通过输入与输出观察模型行为，内部参数、梯度或训练细节不可见或不可直接使用。它与 white-box 视角相对：white-box 更像拿到机器内部图纸，black-box 更像只能从外部按键、观察响应、记录差异。IBM ART 在本章只作为后续工具箱线索出现，具体定义见第七章。

对抗扰动的直觉

对抗样本里的“扰动”需要和随机噪声区分开。随机噪声像随手撒沙子，未必能改变模型输出；对抗扰动更像沿着模型脆弱方向施加压力。防御评估关注的是模型在受控扰动、自然分布变化和边界输入下是否仍能保持可靠行为。

3.3 RAG 与 Vector DB 攻击面

RAG (Retrieval-Augmented Generation, 检索增强生成) 指 LLM 在回答前先检索外部资料，再把检索结果放入上下文中生成回答。它常被用来让模型接入企业知识库、文档库、FAQ、代码库或产品资料。RAG 的优势是把模型从“只靠参数记忆”扩展到“可查资料再回答”；风险也随之扩大，因为外部资料进入了模型上下文。

Vector DB (Vector Database, 向量数据库) 是支撑 RAG 的常见基础设施。它把文本、图片或其他对象转换为 embedding 向量，再按相似度检索相关内容。可以把 Vector DB 想成一座按“语义距离”摆放书籍的图书馆：关键词完全相同并非唯一入口，意义相近的内容也可能被取出来。

因此，RAG 与 Vector DB 的攻击面至少包含三类问题：第一，检索内容是否可信；第二，检索排序是否容易被操纵；第三，进入上下文的文档是否会携带隐藏指令、污染事实或误导工具调用。画面进一步确认，课程会把 Qdrant 与 Pinecone 这类 Vector DB 生态作为 RAG 攻击面示例，同时点名文档投毒、agentic pipelines 以及 SSRF / confused-deputy 风险。

这里的重点仍是概念边界：文档投毒关注被检索资料本身是否携带错误事实或隐藏指令；agentic pipeline 关注模型输出连接工具、检索和外部动作之后的链式影响；SSRF 与 confused-deputy 则提醒学习者，RAG 系统可能借由高权限组件替低权限输入完成不该完成的访问。正文只做风险建模，不给出可执行利用步骤。

C2C 含义需要保留余地

RAG 系统的危险点常常藏在“模型外面”。文档上传、切块策略、embedding、相似度检索、元数据过滤、上下文拼接、权限检查，这些环节都可能改变最终回答。只盯着 LLM 本体，会漏掉检索链路带来的系统级风险。

3.4 Data Poisoning、Backdoors 与 Trigger

Data Poisoning (数据投毒) 指攻击者污染训练数据、微调数据、评估数据或检索语料，使模型在学习、评估或回答时受到错误信号影响。类比做菜时原料被污染：厨师的手艺再好，长期使用问题原料也会做出异常结果。放到机器学习里，数据就是模型学习世界的“食材”和“教材”。

Backdoor (后门) 指模型在普通输入下表现正常，但在特定条件出现时触发异常行为。它的危险在于隐蔽性：常规测试可能看到模型准确率正常，特定触发条件一旦出现，模型行为会偏离预期。后门风险可以发生在训练、微调、模型发布、模型加载和供应链流转等阶段。

Trigger（触发器）是激活后门行为的特定模式或条件。图像模型里常见讲法包括 **pixel trigger（像素触发器）**，也就是某种局部像素模式在后门样本中充当开关。文本、语音、多模态系统中也可以存在其他形式的触发条件。本章只给出抽象定义：Trigger 是让隐藏行为从“潜伏状态”进入“激活状态”的条件。

画面还点名 **Trojans** 与 **sleeper agents**。Trojans 可理解为后门风险的一种课程表达；sleeper agents 强调异常行为可能长期潜伏，只有在特定上下文、触发条件或任务链路中才显现。课程同时强调 *detect and remove*，说明这一模块会讨论如何识别异常模式、定位触发条件，并把风险从数据或模型链路中清除。

把 Data Poisoning、Backdoor、Trigger 放在一起看，链条会更清楚：投毒关注“异常行为怎样被写入系统”，后门关注“异常行为怎样保持隐蔽”，触发器关注“异常行为怎样被唤醒”。这三者把 AI 红队的视野从推理时输入扩展到训练数据、模型来源和生命周期治理。

3.5 C2/C2C Kill Chains 与 Full Red Teaming

Kill Chain（攻击链）指把多个阶段、多个技术点串成一条能解释现实影响的路径。单点漏洞像一颗散落的零件；Kill Chain 像把侦察、进入、影响、扩展、达成目标等环节装成一台完整机器。课程在 03:31 左右提到 C2C Kill Chains，重点是建立链条概念：独立技术只有被放进真实业务路径、权限边界和影响目标中，才容易看出风险等级。

C2（Command and Control，命令与控制）是传统攻防语境中的术语，通常描述攻击者控制基础设施或受控组件的方式。**C2C** 在本课程画面和字幕中多次出现，但上下文尚未充分展开；本章按课程内机制保留该写法，不强行解释成固定行业术语。

Full Red Teaming（全流程红队）指从 scoping 到 report delivery 的完整评估流程。这里的 **scoping** 是确定测试范围、授权边界、资产清单、禁止事项和成功标准；**report delivery** 是把发现、证据、风险评级、复现条件和修复建议交付给相关方。Full Red Teaming 的价值在于把技术发现转化为组织可以处理的风险语言。

CVSS-AI 是课程中提到的 AI 风险评分语境。传统 CVSS 常用于漏洞严重性评分；CVSS-AI 在本章中只作为课程内提到的评分规格来理解，用来提醒读者：AI 风险需要被表达成可比较、可沟通、可交付的严重性判断。它不应被当成已经统一落地的全球标准。

本章压缩

AI 红队的成熟度体现在“从发现到交付”的完整链路。提示词注入、越狱、RAG 风险、对抗样本、数据投毒和后门都只是地图上的节点；攻击链、评分和报告把这些节点连接成管理者能理解、工程团队能修复的风险叙事。

3.6 本章小结

本章完成了 02:11–04:10 这一段的攻击主题全景梳理：Prompt Injection 与 Jailbreaking 负责提示词和模型行为边界；Adversarial ML 进入模型鲁棒性层，覆盖 FGSM、PGD、C&W 等经典概念；RAG 与 Vector DB 把外部检索链路纳入攻击面；Data Poisoning、Backdoor 与 Trigger 把风险推进到数据和训练生命周期；Kill Chain、Full Red Teaming 与 CVSS-AI 则把单点技术整理成完整评估、评分和交付框架。

这张地图的关键价值在于分层：提示词层回答“输入如何改变模型行为”，检索层回答“外部资料如何进入上下文”，数据层回答“学习材料如何被污染”，模型层回答“决策边界如何失稳”，项目层回答“发现如何变成可修复的报告”。后续章节会继续讲学习前置条件、课程模块、实验方法和合规边界。

4 开始前要求：学习者需要什么基础

本 section 使用字幕时间范围：04:10–05:29。本章要解决的问题很直接：学习者开始 AI Red Teaming 之前，最低限度需要准备哪些基础，哪些能力可以边做实验边补。

4.1 本章要解决什么问题

这段课程没有把门槛抬得很高。讲师强调的前置条件主要有六类：Python 基础、命令行舒适度、基本 AI/ML 意识、好奇心与黑客思维、可运行实验的硬件环境，以及 Google Colab 这样的云端运行入口。换句话说，学习者需要能读懂实验、能运行代码、能理解模型训练与推理的大方向，并且愿意追问系统为什么会出错。

前置条件的真实门槛

学习门槛可以概括为一句话：会写一点 Python，会用终端，知道模型从数据中学习并用于推理，愿意在合法实验环境里追问“为什么会坏”。博士级数学背景在这里并非入场券，稳定的动手能力才是课程真正依赖的基础。

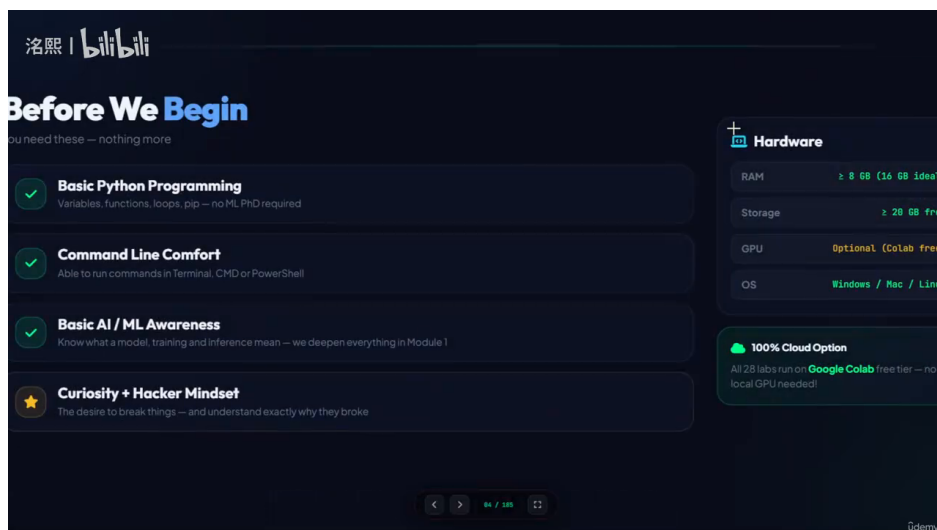


图 6: 课程在“Before We Begin”画面中列出学习前置条件：Python 基础、命令行舒适度、AI/ML 基本意识、好奇心与黑客思维，同时右侧给出硬件和云端实验选项；本图用于帮助读者把学习门槛理解为基础能力与可控实验环境的组合。（视频画面时间区间：04:10–05:25；本帧抽取约 04:12。）

4.2 Python 基础

Python 是本课程最重要的操作语言。学习者至少需要理解变量、函数、循环和包管理这四件事。

- **变量：**变量像给数据贴标签，例如把一段提示词、一个模型输出或一次实验结果保存下来，后续代码就能继续引用。
- **函数：**函数把一组步骤包装成可重复调用的动作。红队实验里，数据加载、模型调用、结果评分都经常被写成函数。

- **循环**：循环用于批量执行，例如对一组测试样例逐条评估模型响应。它让实验从“手工试一次”变成“系统测一批”。
- **pip**：pip 是 Python 常用包管理工具，用来安装课程实验需要的库。学习者至少要知道如何安装、查看和定位依赖问题。

这里的 Python 基础强调“能跟上实验”。学习者无需一开始就掌握大型工程架构，也无需把每个库的内部实现都背下来；先做到能读懂关键代码、能修改少量参数、能看懂报错方向，后续实验才有承接点。

4.3 命令行舒适度

第二个前置条件是能比较自然地使用命令行。课程提到 Terminal、CMD 和 PowerShell，分别对应 macOS/Linux 与 Windows 环境中的常见入口。

命令行可以理解为“用文字指挥计算机”的界面。图形界面适合点击和浏览，命令行适合重复、自动化和精确记录。在 AI 安全实验里，学习者经常需要启动脚本、安装依赖、查看路径、读取日志、传入参数。若每一步都卡在“命令在哪里输入”，实验节奏会被切碎。

ML 生命周期入口

命令行的核心能力不在于记住所有命令，而在于理解三件事：当前目录在哪里，正在运行哪个程序，程序输入和输出分别是什么。用数学语言类比，一个命令可以看成函数

$$f(\text{arguments}) \rightarrow \text{outputs},$$

其中 arguments 是参数，outputs 是屏幕输出、文件结果或日志信息。

4.4 AI/ML 基础意识

第三个前置条件是基本的 AI/ML awareness。这里的 ML 指 Machine Learning，即机器学习：系统从数据中学习模式，并把这些模式用于预测、分类、生成或决策。AI 的范围更宽，ML 是其中很核心的一支；在本课程里，很多攻击主题都围绕“数据怎样影响模型、模型怎样产生输出、输出怎样被评估”展开。

学习者需要先知道三个基础概念：

- **模型**：模型是把输入映射为输出的函数或系统。可写成 $y = f_{\theta}(x)$ ，其中 x 是输入， y 是输出， θ 表示模型参数。
- **training**：训练是让模型从数据中调整参数的过程。直观地说，训练让 f_{θ} 逐渐学会把某类输入对应到期望输出。
- **inference**：推理是训练完成后使用模型的过程。用户输入问题、图片或文档，模型给出回答、标签或判断，这就是 inference。

首次定义 ML 生命周期：ML 生命周期指一个机器学习系统从数据准备开始，经过训练、评估、上线，再到上线后持续监控的完整工程链条。它像一条生产线：原料是数据，中间有加工和质检，最后进入真实使用场景，进入真实场景后还要持续观察质量、偏差和风险。

$$\text{data} \rightarrow \text{training} \rightarrow \text{evaluation} \rightarrow \text{deployment} \rightarrow \text{monitoring}$$

- **data:** 数据是模型学习的原料。数据质量、覆盖范围、标签准确性和污染风险都会影响模型行为。
- **training:** 训练把数据中的模式压缩进模型参数。若训练数据有偏差或被污染，模型可能学到错误关联。
- **evaluation:** 评估用于检查模型在测试集、任务指标和安全约束下表现如何。它相当于上线前的质量检查。
- **deployment:** 部署把模型接入真实应用、API、插件、RAG 系统或业务流程。此时攻击面会从模型本身扩展到接口、上下文、权限和工具链。
- **monitoring:** 监控关注上线后的漂移、异常输入、输出质量、滥用迹象和安全事件。模型上线后仍会遇到训练阶段没有见过的情况。

前文已经提到 Prompt Injection、Adversarial ML、RAG 与 Data Poisoning 等主题。本章只把它们放回学习入口：理解 ML 生命周期后，学习者会更容易看出每类风险落在哪一段链条上。

4.5 好奇心与黑客思维

讲师特别强调 curiosity 和 hacker mindset。这里的黑客思维指一种问题意识：看到系统时，学习者会追问输入从哪里来、边界在哪里、假设能否被打破、错误会怎样传播、权限能否被误用。

这种思维有两个方向。第一，追问 “why they broke”，也就是系统为什么会坏、为什么在某些输入下会偏离预期。第二，追问 “how to fix”，也就是问题被发现后如何修补、限制和监控。AI Red Teaming 的价值正来自这种双向视角：既能像攻击者一样寻找薄弱点，也能像防守者一样把薄弱点转化为改进项。

学习环境底线

黑客思维必须放在授权和实验环境中使用。本章讨论的是学习所需的问题意识，具体合规边界会在后文 Rules of Engagement 中集中展开。学习者在这里先记住底线：只在自己拥有或获得明确授权的环境中实验。

4.6 硬件与运行环境

硬件要求同样偏务实。字幕中给出的门槛是：内存大于 8GB 基本可以开始，存储空间最好超过 20GB，GPU 可以使用但并非强制。操作系统方面，Windows、macOS 或 Linux 都可以承接课程学习。

这些要求背后的原因很简单：AI/ML 实验常常需要安装 Python 包、下载模型或数据、保存中间结果。8GB 以上 RAM 能让常规 notebook 和轻量实验更稳定；20GB 以上存储给依赖、缓存、数据集和输出文件留出空间；GPU 能加速部分训练或推理任务，但课程安排了云端替代方案，避免把本地显卡变成硬门槛。

4.7 Google Colab

Google Colab 是 Google 提供的云端 notebook 环境。学习者可以在浏览器里运行 Python 代码、安装依赖、使用云端算力，并保存实验笔记。它适合教学场景，因为代码、解释、输出和图表能放在同一个 notebook 里，实验过程更容易复现。

课程明确提到 28 个 labs 都可以放在 Google Colab 上运行，本地不需要 GPU。学习者仍然可以选择本地运行，但 Colab 给出了一条更稳的入门路径：先把实验跑通，再根据自己的机器条件迁移到本地环境。

黑客思维的安全版本

Colab 可以理解为“浏览器里的临时实验台”。它降低了硬件门槛，但学习者仍要理解代码在做什么、依赖装在哪里、数据从哪里读取、结果保存到哪里。云端环境解决运行入口问题，理解能力仍要靠学习者自己建立。

4.8 本章小结

本章把课程开始前的准备压缩成六个关键词：Python、命令行、AI/ML 基础、ML 生命周期、黑客思维、Colab/硬件环境。学习者需要的起点并不神秘：能读代码、能跑命令、能理解模型从数据到部署再到监控的链条，并且愿意在合法范围内持续追问系统为什么会出错。具备这些基础后，后续 28 个 labs 才能从“照着点按钮”变成真正的安全学习。

5 课程路线图：模块、实验与交付物

本 section 使用的字幕时间范围为 05:29–06:59。本章要解决的问题是：这门课到底怎样展开，学习者会按什么顺序接触模块、实验与交付物。前文已经铺开了 AI Red Teaming 的攻击主题，本章把这些主题压回一张路线图：先建立基础，再搭建工具，然后进入提示词、检索、对抗机器学习、投毒、模型窃取、供应链、完整红队流程，最后回到防御与未来威胁。



第一部分是引言，我简单介绍了自己。

图 7: 课程路线图全景展示 M0–M11 的路径入口和正式模块排列，并在下方列出 hands-on labs、answer notes、C2C kill chains 与 pro tools 等交付数字；本图用于说明 section 05 讨论的是课程结构和交付物边界。（视频画面时间区间：05:29–06:59；本帧抽取约 05:31。）

5.1 路线图的读法：从 M0 到 M11

05:29 之后，画面切到 *Course Roadmap*。这里的重点不在于每个攻击名的细节，重点在于课程把 AI 红队能力拆成一条从 M0 到 M11 的学习路径：每个模块负责一种学习阶段，每个阶段再通过 labs、answer notes、C2C kill chains 与 pro tools 固化成可练习、可复盘、可交付的材料。



图 8: 路线图局部裁切保留模块格与交付数字，便于读者辨认 Foundation、Lab Setup、Prompt Injection、Jailbreaking、RAG、Adversarial ML、Poisoning、Model Theft、Supply Chain、Full Ops、Defense and Future 等课程阶段；本图用于配合正文解释模块顺序，不展开攻击操作细节。（视频画面时间区间：05:29–06:59；本图由约 05:31 的同一视频帧裁切得到。）

路线图的能力链

路线图可以被理解成一条能力链：

foundation → tools → attack themes → full operation → defense

也就是说，学习者先知道概念和工具在哪里，再学习不同攻击主题怎样影响 AI 系统，随后进入从 scope 到 report 的完整红队流程，最后把发现转化为防御和风险治理。

路线图此处至少能确认涉及 OWASP、MITRE ATLAS 和课程中的 C2/C2C 基础内容；C2C 的完整含义仍以后续课程画面为准。讲义只保留它作为课程内机制名称，不擅自扩写为固定行业标准。

路线图还在 M1 之前显示一个 **M0 Intro / Auth & Setup** 入口，用来承接课程介绍、授权意识和基础设置。随后 **M1 Foundations** 才进入 OWASP、MITRE ATLAS 与 C2C 的基础框架，**M2 Lab Setup** 负责把所有工具安装和实验环境准备好。若正文继续沿用“11 个正式课程模块”的总数，可以把 M0 视为开场与设置入口，把 M1–M11 视为正式课程模块。

5.2 M1–M2：基础与工具

M1 是 Foundations。它承担正式基础框架入口的角色：把前面提到的 AI Red Teaming、攻击面、MITRE ATLAS、OWASP 相关安全框架和 C2/C2C 这些线索放到同一张地图上。这里的“基础”类似航海前的海图：它不会替学习者开船，但会告诉学习者水道、暗礁和边界大概在哪里。

M2 是 Tool Setup。字幕中的“学校设计”结合上下文应校正为工具搭建。这个模块的任务是准备实验环境和课程工具，使后续 labs 可以运行。前一章已经说明 28 个 labs 可通过 Google Colab 完成，因此 M2 更像实验台搭建：确认运行环境、依赖、模型和测试工具就位，随后才进入具体攻防主题。

工具搭建的边界

工具搭建只服务于授权学习和可控实验。路线图里出现工具、模型仓库、序列化文件和红队流程，并不表示可以把这些内容迁移到未授权系统上测试。合规边界会在后文集中展开，本章只讲课程结构。

5.3 M3–M6: 提示词、越狱、RAG 与对抗 ML

M3 是 Prompt Injection。路线图明确写出 7 techniques 与 7 labs。这里沿用前文定义：Prompt Injection 是通过输入或上下文影响模型指令遵循方式的一类风险。M3 的数字含义很清楚，课程会用 7 个实验让学习者理解这一主题的不同形态。

M4 是 Jailbreaking。画面和字幕给出 5 categories 与 5 labs。Jailbreaking 已在前文定义为绕过安全对齐或策略限制的技术类别。本章只记录课程排布：它在 Prompt Injection 之后出现，说明课程会先讲输入控制，再讲安全边界被挑战时的行为。

M5 是 RAG Exploits 与 Vector DB Attacks。RAG 与 Vector DB 的定义见前文。放在这里的教学意义是：AI 系统的输入不只来自用户当前的一句话，也可能来自检索文档、embedding 索引和向量数据库。课程把 RAG 与 Vector DB 单列成模块，说明它会把检索链路看成 AI 攻击面的一部分。

M6 是 Adversarial ML。该处按标准术语整理为 FGSM、PGD、C&W。它们都属于前文提到的对抗机器学习方法。可以把这一模块想成“模型决策边界压力测试”：输入 x 经过小扰动 δ 后，模型输出可能从 $f_{\theta}(x)$ 变为 $f_{\theta}(x + \delta)$ ，课程关注的是这种变化怎样暴露鲁棒性问题，本章不展开构造扰动的具体步骤。

5.4 M7–M10: 投毒、模型窃取、供应链与完整红队流程

M7 是 Data Poisoning 与 Trojans。字幕说 poisoning 是讲师很感兴趣的课题，并提到 Trojans。这里的 Trojans 可按后门相关风险理解：训练或部署链路中埋入特定触发条件，使模型在某些输入下表现异常。Data Poisoning 与 Backdoor 的定义见前文，本章只说明它们在路线图中承接 Adversarial ML，开始从“输入扰动”走向“数据与训练链路”。

M8 是 Model Theft、Model Extraction 与 Model Inversion。这是本章的首次定义区。

Model Theft，中文可译为“模型窃取”，指攻击者试图获取模型参数、模型文件、接口行为、训练成果或等价替代模型的风险类别。它关心的是模型作为资产被拿走、被复制或低成本复刻。

Model Extraction，中文可译为“模型抽取”，指通过查询接口、观察输出、利用泄露信息等方式重建模型能力。用数学语言表达，它追求的是构造一个近似模型：

$$\hat{f}(x) \approx f_{\theta}(x)$$

其中 f_{θ} 是目标模型， $\hat{f}$ 是被重建出的替代模型。这个公式只帮助理解“抽取”的方向：从可观察行为逼近隐藏模型。

Model Inversion，中文可译为“模型反演”，指从模型输出、置信度、梯度或响应模式中反推训练数据特征、敏感属性或代表性样本的风险。它像从脚印倒推鞋底纹路：观察的是模型输出，暴露的可能是数据痕迹。

M9 是 Supply Chain Attacks。Supply Chain Attack，中文可译为“供应链攻击”，指依赖包、模型仓库、预训练权重、序列化文件、镜像、部署脚本等环节被污染后，风险沿着开发与部署链路传递。字幕明确提到 Pickle、HF Hub 和 Hugging Face Model，因此本章只将它们作为供应链风险的课程对象：Pickle 代表序列化文件风险，Hugging Face Hub 代表模型分发与复用生态中的信任问题。

M10 是 Full Red Team Operations。字幕提到从 scope 到 report，说明这个模块负责把前面分散的主题组织成完整项目流程。Scope 是范围界定，Report 是报告交付；它们像红队项目的入口门和出口门。没有 scope，测试边界会失控；没有 report，发现无法转化为修复行动。

5.5 M11：防御与未来威胁

M11 是 **Defense and Future**，包含 **Agentic AI Threats**。Agentic AI Threats，中文可译为“智能体式 AI 威胁”，指具备规划、工具调用、环境交互或自主执行能力的 AI 系统带来的风险。普通聊天模型主要生成文本；agentic AI 会把“想法”接到工具、文件、浏览器、代码执行器或业务系统上，因此风险会从回答错误扩大到行动错误、权限误用和链式影响。

这个模块被放在路线图最后，很有教学含义：课程没有把 AI 红队停留在攻击主题清单上，而是把终点放到防御与未来方向。红队工作若只制造问题，价值很有限；真正的交付物要能帮助团队理解风险、修正控制、改进监控和降低系统暴露面。

5.6 交付物数字：28 labs、28 answer notes 与 C2C kill chains

路线图底部的四个交付数字应按画面精确写作：28 个 hands-on labs、28 份 answer slides / answer notes、6 条 C2C kill chains，以及 8+ 个 pro tools。这里的 kill chains 强调课程会把技术点串成攻击链视角；pro tools 强调课程会接触实际安全评估工具。二者都服务于教学化练习和复盘，不构成未授权测试许可。

这组数字说明课程具有强实验属性。Labs 是练习场，answer notes 是复盘材料，C2C kill chains 是课程中特别标出的链式风险线索，8+ pro tools 则对应课程会接触的专业工具集合。若用教学流程表示，可以写成：

module → lab → answer note → reflection

模块给出知识边界，lab 提供受控练习，answer note 解释预期结果与分析思路，reflection 让学习者回到“为什么会坏、怎样修”的问题上。

交付物数字

本章最关键的数字是 11、28、28、6 和 8+：11 个正式课程模块，28 个 labs，28 份 answer notes，6 条 C2C kill chains，以及 8+ 个 pro tools。它们共同描述课程规模，但不能被误读成攻击清单或实战授权。

5.7 本章小结

本章把 05:29–06:59 的课程路线图整理为一条清晰路径：M0 承接介绍、授权与设置，M1 建立基础，M2 搭建工具，M3–M6 覆盖 Prompt Injection、Jailbreaking、RAG/Vector DB 与 Adversarial ML，M7–M10 进入投毒、Trojans、Model Theft、Model Extraction、Model Inversion、Supply Chain Attack 和 Full Red Team Operations，M11 收束到 Defense、Future 与 Agentic AI Threats。课程交付物由 28 个 labs、28 份 answer notes、6 条 C2C kill chains 和 8+ 个 pro tools 构成，定位是教学、练习与复盘，不提供未授权操作指南。

6 学习方法与视觉规则：理论、Demo、Lab、Challenge

本 section 使用的字幕时间范围为 06:59–08:04。本章要解决的问题是：这门 AI Red Teaming 课程到底怎样学，学习者在看到 Theory、Demo、Hands-on Lab、Challenge 与 Answer Notes 时，应如何理解它们之间的顺序与角色。

前文已经讲过课程路线图和 28 个 labs。本章不重复解释每一种攻击主题，只解释学习过程本

身。课程把知识拆成一个循环：

Theory → Demo → Hands-on Lab → Challenge/Answer Notes

这个循环像安全训练里的“看地图、看示范、进靶场、做复盘”：先知道概念，再看技术如何被展示，随后在受控环境里动手，最后通过挑战和答案笔记检查理解是否落地。

学习循环

这一章的核心规则很简单：Theory 负责建立概念，Demo 负责展示过程，Hands-on Lab 负责让学习者亲自执行并观察结果，Challenge 和 Answer Notes 负责把“做过”推进到“理解过”。若只看讲解，知识容易停在名词层；若只跟着操作，实验容易变成机械点击。课程用四段式循环把两者接起来。



图 9：课程画面展示“*How This Course Works*”的学习循环：Theory、Demo、Hands-on Lab、Challenge 与 Answer Notes，并在下方标出绿色、蓝色、橙色边框分别对应 Lab、Answer Notes 与 C2/C2C slides。该图用于说明本章的学习方法和视觉规则。（视频画面时间区间：约 00:07:05，位于 section_06 的 06:59–08:04 窗口内。）

6.1 四段式学习循环

06:59 之后，画面切到 *How This Course Works*。讲师把课程学习方式分成几个连续部分：先学理论，再进入 Demo，然后做 Hands-on Lab，最后进入 Challenge 和 Answer Notes。这里的顺序很关键，因为 AI 安全学习常见的困难就在于：概念、工具、现象和结论混在一起时，学习者很容易知道术语，却不知道术语怎样落到实验里。

Theory 可以理解为“地图层”。它回答这类问题：这个主题是什么，风险出现在系统的哪一段，现实世界里为什么值得关注。Demo 可以理解为“示范层”。它把地图上的路线演给学习者看，使学习者看到一次完整过程。Hands-on Lab 是“实验层”。学习者在受控环境中逐步执行、观察命令含义和预期结果。Challenge 与 Answer Notes 是“复盘层”。学习者先尝试独立解决，再用答案材料检查路径、结果和分析。

用更工程化的方式看，这个循环对应四个状态：

concept → demonstration → execution → reflection

其中 *concept* 让学习者知道对象, *demonstration* 让学习者看到方法, *execution* 让学习者获得经验, *reflection* 让经验沉淀成判断力。

6.2 理论与图示：先建立问题框架

Theory, 中文可译为“理论讲解”或“概念层”, 指课程中用于解释核心概念、图示和现实案例的部分。字幕提到学习者会看到 *concepts*、*diagrams* 和 *real-world concepts*。这里的“理论”并非抽象空谈; 它为实验建立坐标系。

例如前文提到的 Prompt Injection、RAG、Adversarial ML、Data Poisoning 和 C2/C2C, 都属于不同攻击主题。到了本章, 课程关心的是学习者怎样学这些主题: 先用概念知道风险在哪里, 再用图示看清输入、模型、数据、检索链路或工具链之间的关系。图示的作用类似电路图: 它不会代替实验, 但能让学习者知道电流大概从哪里进、从哪里出、哪里可能短路。

Demo 的作用

安全课程中的“理论”可以被理解为对攻击面的建模。若把一个 AI 系统看成函数链

$$x \rightarrow \text{retrieval} \rightarrow \text{model} \rightarrow \text{tool/API} \rightarrow y,$$

理论层要说明每个环节代表什么、哪些输入可能改变系统行为、哪些输出需要被评估。这样进入实验时, 学习者看到的内容会从一个串命令扩展为一条可解释的因果链。

6.3 Demo 与 Hands-on Lab：从观看到执行

Demo 是 *demonstration* 的缩写, 中文可译为“演示”。在本课程中, Demo 指讲师展示某一类攻击技术或测试流程的过程。它的重点是让学习者看到步骤如何连接、现象如何出现、结果如何被解释。Demo 更像教练先完整做一遍动作: 学习者先观察节奏和关键点, 再进入自己的练习。

Hands-on Lab, 中文可译为“动手实验”或“实操实验”, 指学习者亲自执行课程提供的实验步骤。字幕明确提到 *step-by-step execution*、理解正在做什么、如何做、每个命令的含义, 以及预期结果。这里的 Hands-on 有两个含义: 第一, 学习者要动手运行; 第二, 学习者要在运行中理解命令和结果之间的关系。

课程中的 Lab 应被理解为受控实验环境内的训练材料。它通常有输入、步骤、观察点和预期结果。若用实验结构表示, 可以写成:

$$\text{instruction} + \text{environment} + \text{observation} \rightarrow \text{learning}$$

其中 *instruction* 是步骤, *environment* 是受控环境, *observation* 是输出和现象, *learning* 是对风险、边界和修复方向的理解。

Challenge 与 Answer Notes

Hands-on Lab 的目标高于“跑完即可”: 它要建立可解释的操作记忆。学习者需要知道每个命令大致在调用什么、改变什么、输出什么, 以及预期结果为什么能证明某个安全现象存在。

6.4 Challenge 与 Answer Notes：自测与复盘

Challenge, 中文可译为“挑战任务”或“自测任务”, 指学习者在看过理论、Demo 和 Lab 后, 尝试独立完成的练习。它的教学价值在于制造一个小的空白区: 学习者不能完全依赖讲师逐步提

示，需要自己判断下一步该看什么、改什么、验证什么。

Answer Notes，中文可译为“答案笔记”或“解析笔记”，指课程提供的答案、预期结果、分析说明和学习要点。字幕提到学习者会得到 expected results、analysis、learning 和 what we learned。Answer Notes 的价值不只在给出答案，也在于解释为什么这个结果是合理的、哪里容易误判、实验结束后应该带走哪些安全判断。

Challenge 与 Answer Notes 合在一起，形成一组学习闭环：

attempt → compare → analyze → adjust

学习者先尝试，随后对照答案，再分析差距，最后修正自己的理解。这个闭环对于 AI 红队学习尤其重要，因为很多 AI 系统具有非确定性：同一个输入在不同模型、不同参数、不同上下文下可能产生差异。答案笔记帮助学习者区分“结果不同但方向正确”和“理解已经偏离主题”。

6.5 幻灯片颜色约定

这段视频最后给出非常实用的视觉规则。学习者在后续课程里可以通过边框颜色快速识别当前材料类型：

- **绿色边框**：表示 Lab slides，也就是 Hands-on Lab 相关幻灯片。看到绿色边框时，学习者应准备进入动手实验、命令理解和结果观察。
- **蓝色边框**：表示 Answer Notes，也就是答案笔记或解析材料。看到蓝色边框时，学习者应把注意力放在预期结果、分析路径和复盘要点上。
- **橙色边框**：表示 C2/C2C slides。C2 的定义见前文；C2C 在前文仅作为课程内机制名称保留。本章只把橙色边框作为课程视觉分类规则，后续机制含义仍按课程画面展开。

颜色约定看似只是版式细节，实际承担“导航”作用。绿色提醒学习者进入练习，蓝色提醒学习者进入解析，橙色提醒学习者进入课程中特别标出的 C2/C2C 内容。对于一门包含 28 个 labs、28 份 answer notes 和多个机制主题的课程，这种视觉导航能降低认知负担：学习者不用每次重新猜当前页面属于讲解、实验还是复盘。

颜色作为元数据

颜色规则可以看成一种轻量级元数据。若把每张 slide 看作一个对象 s_i ，边框颜色就是它的标签 $label(s_i)$ ：绿色对应 Lab，蓝色对应 Answer Notes，橙色对应 C2/C2C slides。标签本身不增加技术内容，却能帮助学习者快速选择阅读策略。

6.6 本章小结

本章覆盖 06:59–08:04 的学习方法说明。课程采用 Theory → Demo → Hands-on Lab → Challenge/Answer Notes 的学习循环：理论建立框架，Demo 展示过程，Hands-on Lab 让学习者在受控环境中逐步执行，Challenge 和 Answer Notes 用来自测与复盘。视觉规则也很明确：绿色边框表示 Lab，蓝色边框表示 Answer Notes，橙色边框表示 C2/C2C slides。后续学习时，学习者可以先看边框判断当前材料类型，再选择相应的学习动作。

7 合规边界、工具箱与最终总结

本章对应视频时间范围约为 08:04–10:49。08:04–10:00 的字幕集中说明交战规则、实验环境、负责任披露、防御目标与工具箱；10:00–10:49 缺少字幕，讲义只依据画面中出现的下一讲标题 *Foundations of AI Red Teaming* 做谨慎收束，不补写讲者未展开的技术内容。

7.1 本章要解决什么问题

前文已经完成课程定位、讲师背景、攻击主题、学习前置条件、路线图和学习方法。本章承担最后一块地基：学习者在进入实验前，必须知道哪些事情绝对需要授权，哪些环境可以承接练习，发现真实问题时怎样处理，以及课程工具箱在整套学习机制中各自站在哪里。

可以把 AI Red Teaming 看成一台压力测试仪。压力测试仪的价值在于提前暴露结构脆弱点，帮助工程团队补强系统；如果脱离授权范围，它立刻会从安全评估滑向违法测试。这里的边界没有灰色浪漫，只有范围、授权、记录、披露和责任。

合规底线

本章的核心句可以压缩为一句话：AI 红队测试必须在明确授权、受控环境和防御目标之内进行。工具只是放大器，合规边界决定它放大的到底是安全能力，还是法律风险。

7.2 Rules of Engagement：授权优先

Rules of Engagement，中文可译作“交战规则”，指一次安全测试开始前写清楚的边界协议。它通常回答五类问题：测试谁的系统、允许测试哪些资产、允许在什么时间窗口测试、哪些技术类别可以触碰、发生异常时怎样停止和联络。类比现实中的消防演练，演练可以模拟烟雾、疏散和应急流程，但楼层、时间、人员、出口、警报触发条件都要先写清楚。

Written Authorization，中文可译作“书面授权”，指系统所有者或有权代表方以可追溯文字形式给出的许可。它的重点在“书面”和“有权”：口头一句“试试看”很难证明范围；无权人员的同意也不能覆盖真实法律责任。视频在这一段把要求说得很硬：不要测试自己不拥有、没有明确书面授权的系统。这属于法律底线，不能当作礼貌建议。

从集合视角看，授权范围可以写成：

$$S_{\text{allowed}} = A \cap T \cap M \cap W$$

其中 A 表示获批资产集合， T 表示获批时间窗口， M 表示获批方法类别， W 表示书面授权文本覆盖的约束。一次测试只有落在 S_{allowed} 内，才算进入合规边界。任何一个维度越界，风险都会急剧上升。

未授权测试的后果

未授权测试真实系统会带来法律、职业和安全后果。课程中的攻击主题只能放在自有系统、明确授权系统、本地模型、沙盒平台或课程实验环境中练习；生产系统、第三方账号、公开服务和他人数据都不能被当作练手对象。

7.3 实验室环境与 Responsible Disclosure

视频随后强调实验室环境。这里的“实验室”不只是一个文件夹或一台电脑，它是一组可控条件：本地模型、沙盒平台、隔离数据、可复原配置、可观察日志，以及不会影响真实用户的运行

边界。安全训练需要这种环境，就像医学训练需要模拟器，航空训练需要飞行模拟舱；核心目的都是让学习者在可承受的代价内理解风险。

Responsible Disclosure，中文可译作“负责任披露”，指发现真实漏洞后，通过合规渠道通知受影响方，并给出合理修复窗口和必要证据。它关注三个动作：及时报告、控制传播、配合修复。这里的“披露”需要避开公开炫技，更接近把火警信号准确交给负责灭火的人，同时避免围观者把问题扩大。

在 AI 系统里，真实漏洞可能来自提示词边界、RAG 文档链路、模型接口、工具调用权限、训练数据、供应链依赖或日志泄露。前文已经介绍这些攻击面，本章给出的约束是：一旦这些问题出现在真实系统中，学习者应走合规报告流程，保留最小必要证据，避免扩散敏感内容，避免把验证动作升级成破坏行为。

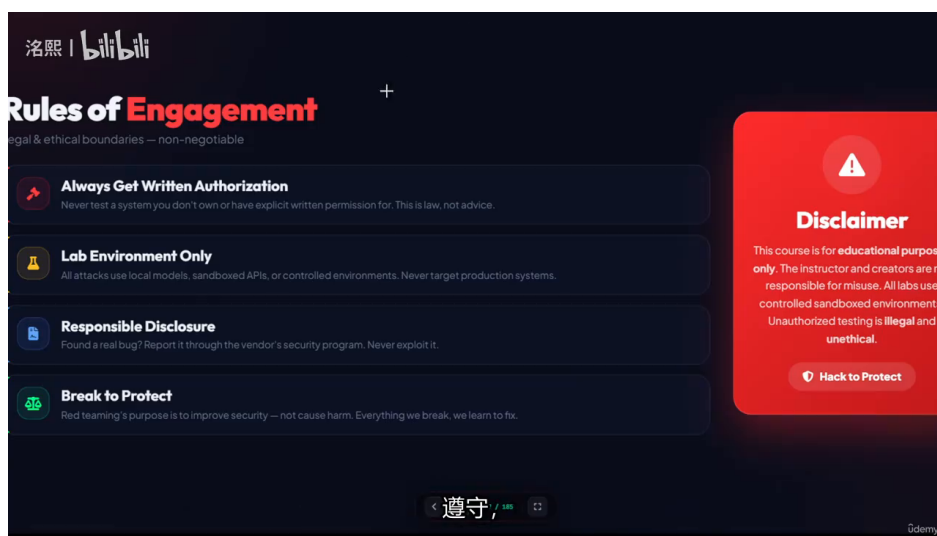


图 10: 课程画面展示“Rules of Engagement”：书面授权、实验室环境、负责任披露与以保护为目标的原则，并在右侧给出免责声明。该图用于承接本章对授权边界和合规底线的说明。（视频画面时间区间：约 00:08:10，位于 section_07 的 08:04–10:49 窗口内。）

工具箱之后，画面转入下一讲标题页；这一页只作为课程衔接，避免在字幕缺口处补写没有画面依据的细节。

7.4 防御目标：break to protect

讲者在合规段落里反复把目标拉回防御：红队的目标是保护安全、修复问题、降低风险。换句话说，红队的价值在于让团队提前看到系统在压力下会怎样失稳，进而把发现转化为修复、检测和治理动作。

可以用一个简单风险函数组织这个目标：

$$R = P(\text{failure}) \times I(\text{impact})$$

其中 $P(\text{failure})$ 是失败发生概率， $I(\text{impact})$ 是影响强度。AI 红队测试的教学意义在于找到会放大 P 或 I 的路径，再通过修复、检测、隔离、权限收敛和流程改进把 R 降下来。这里的“攻击”是诊断动作，“修复”才是课程要导向的工程结果。

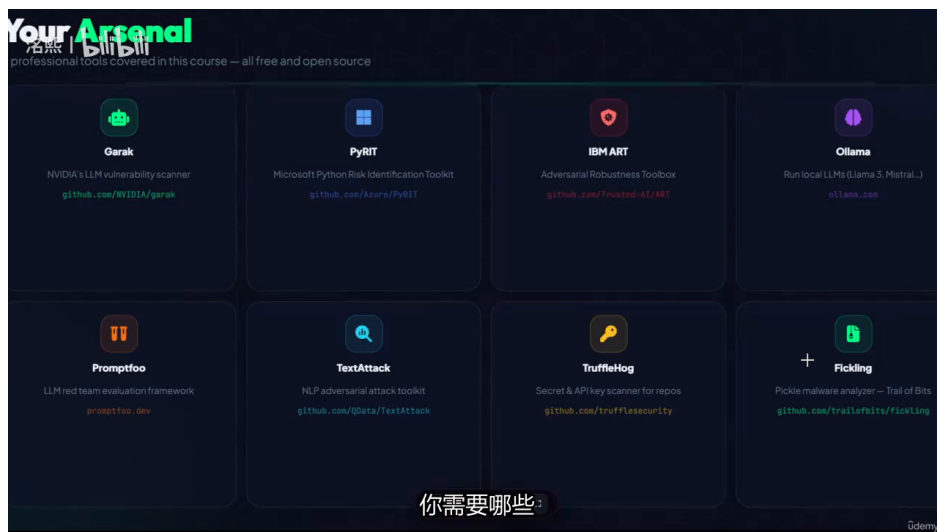


图 11: 课程画面展示 “Your Arsenal” 工具箱总览，可见 Garak、PyRIT、IBM ART、Ollama、Promptfoo、TextAttack、TruffleHog 与 Fickling 等工具卡片。该图用于说明课程会接触的工具类别，不展开安装命令或攻击步骤。（视频画面时间区间：约 00:09:40，位于 section_07 的 08:04–10:49 窗口内。）

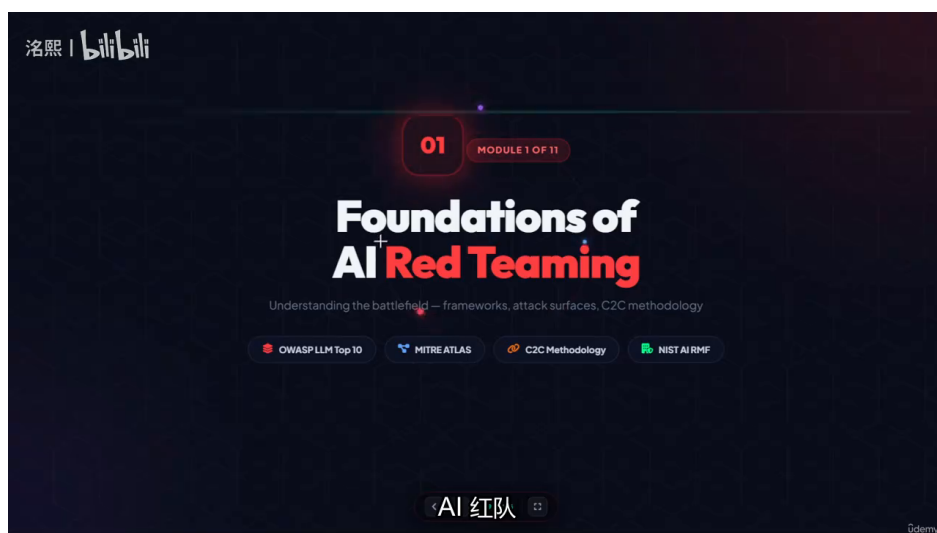


图 12: 课程画面展示下一讲入口 “Foundations of AI Red Teaming”，并列出 OWASP LLM Top 10、MITRE ATLAS、C2/C2C 相关方法与 NIST AI RMF 等标签。该图用于说明开篇课程收束到 Foundations 模块。（视频画面时间区间：约 00:10:25，位于 section_07 的 08:04–10:49 窗口内。）

AI 红队测试的额外难点

AI 红队测试与传统渗透测试共享授权、范围和报告意识，但 AI 系统额外带来非确定性输出、数据依赖、提示词上下文、检索链路和模型行为漂移。相同输入未必得到相同输出，这会让测试更像采样评估：需要记录环境、模型版本、数据版本、提示上下文和观察到的结果。

7.5 Your Arsenal: 课程工具箱

视频约 09:40 进入 *Your Arsenal*，也就是课程工具箱。这里的“arsenal”应理解为学习资源和评估工具集合，需避免被理解成攻击指令仓库。工具的作用是帮助学习者更系统地观察、评估和记录 AI 风险。

画面把这组工具标注为 *all free and open source*，这意味着课程工具箱强调可获得性和可复查性。学习者可以在合法环境中使用这些工具做评估记录、模型行为观察、鲁棒性实验、提示词测试或凭据卫生检查；正文仍不提供安装命令和攻击步骤。

Garak 是面向大语言模型的安全评估工具，常用于组织不同类别的探测、记录模型响应，并帮助识别提示词、输出安全和模型行为层面的风险信号。它像一套体检项目清单，价值在于覆盖面和可复查记录。

PyRIT 是生成式 AI 红队测试相关的风险识别工具包。它通常用于把测试目标、提示模板、响应记录和评估逻辑组织起来，让红队测试更接近可重复的工程流程。这里需要记住的是“风险识别”和“流程化记录”；具体攻击技巧不属于本段重点。

IBM ART 指 IBM 的 *Adversarial Robustness Toolbox*，中文可译作“对抗鲁棒性工具箱”。它主要服务于机器学习模型的鲁棒性评估、防御研究和对抗样本相关实验。前文提到的 Adversarial ML 可以把模型看作函数 $f_{\theta}(x)$ ，ART 一类工具关注的是输入扰动、模型输出变化和防御效果之间的关系。

NIST Toolbox 在本课程语境中指 NIST 相关的 AI 风险管理、可信 AI、安全测评与治理参考资源。它更像标尺和地图：标尺用于校准风险语言，地图用于把技术发现放回治理、文档、控制项和组织流程中。

Ollama 是本地运行大语言模型的工具。课程把本地模型放入工具箱，原因很直接：本地环境更容易控制数据、版本和测试边界，也更适合课程实验中的重复观察。

Promptfoo 是用于提示词、模型输出和评估用例管理的测试工具。它可以帮助学习者比较不同提示、模型或配置的输出差异，把“感觉这个回答不稳”变成更有结构的评估记录。

TextAttack 是自然语言处理领域的对抗样本、数据增强和鲁棒性评估工具。它适合放在 NLP 模型测试的学习入口中，用来理解文本扰动、分类器行为和鲁棒性之间的关系。

TruffleHog 是面向密钥和敏感凭据泄露的扫描工具。它提醒学习者：AI 安全不只发生在模型输出层，代码仓库、配置文件、日志、数据集和模型卡里也可能藏着高风险信息。对 AI 项目而言，供应链和凭据卫生是基础防线。

Fickling 若按画面保留，可概括为与 Pickle 文件安全检查相关的工具。本讲义只点名其课程工具箱位置，不写安装命令或使用步骤。

7.6 最终总结：从开篇到 Foundations

这节开篇课的实质性收束可以分成四层。

第一层是课程目标：AI Red Teaming 围绕攻破、测试与保护 AI 系统展开，最终服务于安全改进。第二层是攻击主题地图：Prompt Injection、Jailbreaking、Adversarial ML、RAG/Vector

DB、Data Poisoning、Backdoor、C2/C2C Kill Chain、Full Red Teaming 等模块构成一张从输入到模型、从数据到供应链、从单点技术到完整交付的路线图。第三层是学习机制：Theory、Demo、Hands-on Lab、Challenge、Answer Notes 形成循环，绿色、蓝色、橙色边框帮助学习者识别实验、答案笔记和 C2/C2C slides。第四层是实践边界：所有练习必须回到授权、实验室环境、负责任披露和防御目标。

这四层合在一起，就是本课程的核心机制压缩：

Learn → Test → Observe → Report → Reduce Risk

学习需要越过术语表，测试需要越过演示效果，报告需要越过问题截图；它们最终都要汇入风险降低。对工程团队来说，一份好的 AI 红队结果应该能回答：问题在哪里、为什么会发生、影响多大、如何用最小必要证据证明、怎样修复、怎样防止复发。

视频最后约 10:20–10:49 的画面显示下一讲入口为 *Foundations of AI Red Teaming*，并出现 MITRE ATLAS、C2/C2C 与 NIST AI 风险管理等提示。由于这一段没有字幕，讲义只把它理解为课程进入基础框架的过渡：下一步将从开篇路线图走向更系统的基础概念、风险语言和框架化思维。

7.7 本章小结

本章完成了开篇课的最后收束：Rules of Engagement 规定测试边界，Written Authorization 给出合法前提，Responsible Disclosure 规定真实漏洞的处理方式；实验室环境把风险关进可控空间，防御目标把红队活动导向修复和风险降低。Garak、PyRIT、IBM ART、NIST Toolbox、Ollama、Promptfoo、TextAttack、TruffleHog 构成课程工具箱，但工具的价值取决于合规使用和清晰记录。到这里，学习者已经拿到课程地图、学习方法、实践边界和下一讲入口，可以进入 *Foundations of AI Red Teaming*。